

# **MEDICARE CONNECT (PTY) LTD INCIDENT CLASSIFICATION GUIDE**

Classification: Internal

Version: 1.0

Date: March 2026

Author: Patrick Mohlala, GRC Analyst

Review Date: March 2027

## **1. PURPOSE**

This guide ensures all staff classify security incidents consistently so the correct response is triggered at the correct speed every time.

Misclassifying a Critical incident as Low is one of the most common causes of missed POPIA notification deadlines.

## **2. WHAT IS AN INCIDENT?**

An information security incident is any event that actually or potentially:

- Compromises the confidentiality of patient or staff personal information
- Affects the integrity of medical records
- Disrupts availability of clinical systems
- Violates POPIA obligations
- Breaches MediCare Connect security policies

An event that could have caused harm but did not is a NEAR MISS and must also be reported and logged.

## **3. SEVERITY TIERS**

### **Tier 1 – Critical**

Definition: Confirmed breach of patient medical records or personal information. Active attack in progress. Full system compromise. Clinical operations halted.

#### **Examples:**

- Ransomware encrypting patient database
- Confirmed unauthorised access to Patient Health Record System
- Stolen unencrypted laptop with patient data
- Attacker actively inside the network
- Mass accidental disclosure of patient records

POPIA Reportable: YES – ALWAYS

Response time: IMMEDIATE (within 1 hour)

Who to notify: CEO + IT Manager + Information Officer (same time)

Information Regulator: Within 72 hours of discovery

Patient notification: Required if high risk of harm

External support: Cyber insurer activated

### **Tier 2 – High**

Definition: Suspected breach under investigation. Significant system degradation. Single user account compromised. Malware detected and contained but origin unknown.

#### **Examples:**

- Phishing email clicked and credentials entered
- Single staff account compromised
- Malware detected and quarantined

- Unusual access patterns in patient records
- Laptop lost and encryption status unknown

POPIA Reportable: POSSIBLY – assess impact

Response time: Within 4 hours

Who to notify: IT Manager + Information Officer

Action: Prepare notification in case breach is confirmed

### **Tier 3 – Medium**

Definition: Security policy violation without confirmed data exposure. Isolated malware blocked. Minor physical security breach.

#### **Examples:**

- Staff sharing password (caught before exploitation)
- Phishing email received but not clicked
- Antivirus blocked malware download
- Visitor found in restricted area
- Single misdirected email with non-sensitive information

POPIA Reportable: UNLIKELY – document only

Response time: Within 24 hours

Who to notify: IT Manager

Action: Log in incident register

### **Tier 4 – Low**

Definition: Near miss or policy awareness issue. No systems affected. No data at risk.

#### **Examples:**

- Workstation left unlocked (locked by colleague)
- Suspected phishing reported before any action taken
- Password reset required
- Visitor badge not returned

POPIA Reportable: NO

Response time: Within 5 business days

Who to notify: Log only

## **4. POPIA REPORTABILITY DECISION TREE**

Ask these questions in order:

Q1: Was personal information accessed, acquired, used, disclosed without authorisation, OR lost?

NO → Document as internal incident. POPIA notification not required.

YES → Go to Q2

Q2: Does the personal information belong to an identifiable living person?

NO → Document as internal incident.

YES → Go to Q3

Q3: Could the breach cause harm to the affected persons?

(Financial loss, reputation damage, discrimination, physical harm, identity theft, distress)

NO → Document internally. Consider voluntary notification.

YES → POPIA SECTION 22 APPLIES

Notify Information Regulator within 72 hours

Notify affected data subjects as soon as reasonably possible

WHEN IN DOUBT: Classify higher. Start the 72-hour clock. You can cancel a notification. You cannot reverse a missed deadline.

## **5. INCIDENT CATEGORIES**

CAT-01 Malware and Ransomware  
CAT-02 Phishing and Social Engineering  
CAT-03 Unauthorised Access  
CAT-04 Data Loss or Exposure  
CAT-05 Physical Security Breach  
CAT-06 Insider Threat  
CAT-07 Third Party or Vendor Incident  
CAT-08 System Availability Failure  
CAT-09 Policy Violation  
CAT-10 Near Miss

## **6. WHO CAN DECLARE AN INCIDENT**

Any staff member can and must report a suspected incident.

Only these roles can formally classify and declare:

- IT Manager
- Information Officer
- GRC Analyst
- CEO (if others unavailable)

Document Control

Prepared by: Patrick Mohlala, GRC Analyst

Version: 1.0 | Status: Final | Review: March 2027